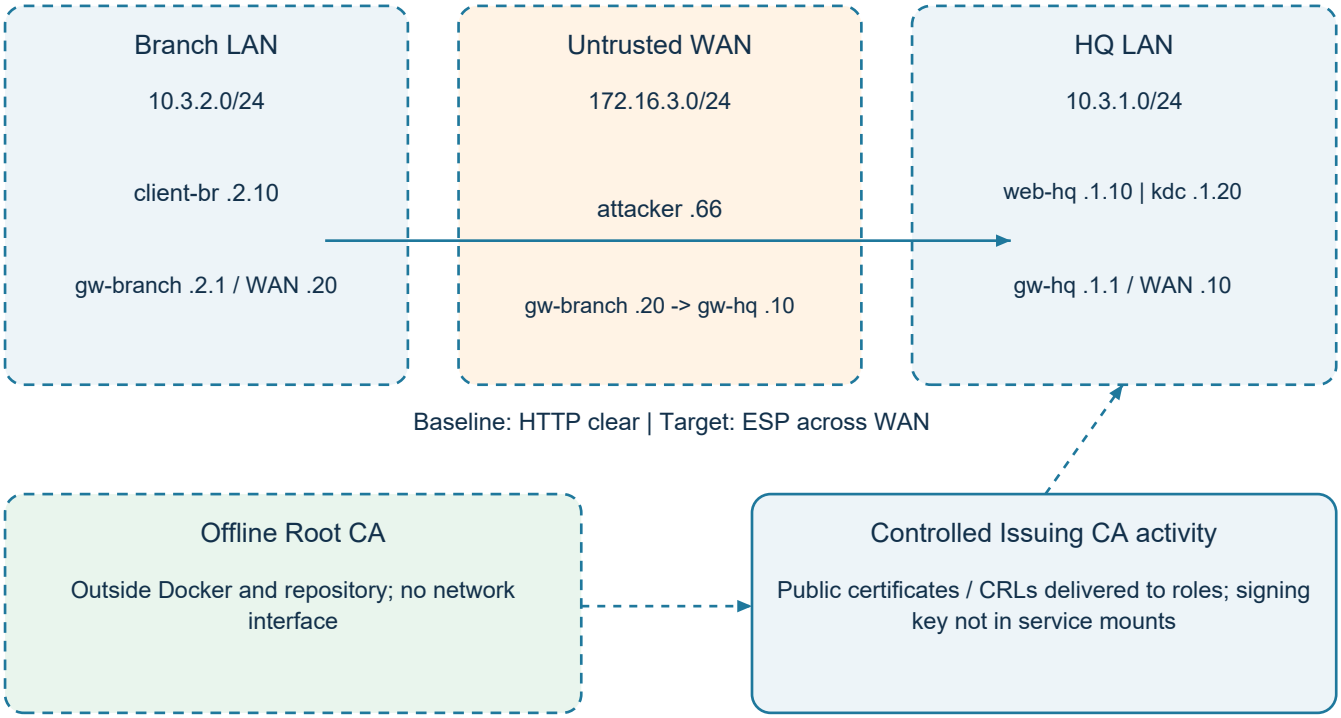
Topology and Trust Boundaries

Group 03 | Address component G=3 | M1 baseline and target design

Network view

The diagram separates four trust domains: Branch LAN, untrusted WAN, HQ LAN, and offline Root CA. Only six nodes run in Docker; CA signing is an administrative activity, not a seventh service node.



Network	CIDR / Docker bridge gateway	Trust and ownership
WAN	172.16.3.0/24 / .254	Untrusted; both gateways and authorized attacker.
HQ LAN	10.3.1.0/24 / .254	HQ services; use gw-hq .1 for cross-campus routes.
Branch LAN	10.3.2.0/24 / .254	Staff client; use gw-branch .1 for HQ routes.
Offline CA	No lab interface/address	Encrypted Root key outside repository and every Docker bind mount.

Docker .254 addresses reserve bridge infrastructure, not campus routing. Endpoints delete the Docker default route and use only explicit lab routes; gateways have no external default. Interface names are discovered by assigned IPv4, never assumed eth0. Every network is internal with masquerading disabled, IPv6 disabled and no published host ports. Docker-host administrators remain trusted; container networks are not a boundary against a compromised host.

Six-node inventory

Node / FQDN	Address(es)	Role / attached networks
gw-hq.g03.scp.lab	172.16.3.10; 10.3.1.1	WAN + HQ; route baseline, future VPN endpoint.
gw-branch.g03.scp.lab	172.16.3.20; 10.3.2.1	WAN + Branch; route baseline, future VPN endpoint.
web-hq.g03.scp.lab	10.3.1.10	HQ; baseline HTTP, later TLS portal, CRL and service.
kdc.g03.scp.lab	10.3.1.20	HQ; idle in M1, future KDC.
client-br.g03.scp.lab	10.3.2.10	Branch; HTTP client, future mTLS/Kerberos client.
attacker.g03.scp.lab	172.16.3.66	WAN only; explicit route to Branch via gw-branch, no HQ route.

portal.g03.scp.lab and pki.g03.scp.lab map to 10.3.1.10. Static /etc/hosts entries supply lab resolution; no university DNS is changed. Gateway certificate names and IKE identities use these same FQDNs. Source of group identity: user-confirmed G3, normalized to 03/3.

Permitted flows and baseline routing

Flow	M1 baseline	Future target (design only)
client-br -> web-hq	TCP 80, HTTP GET /baseline.txt; known text SCP-M1-G03-HTTP-CLEAR. ICMP for reachability.	Inner HTTPS TCP 443, protected across WAN by ESP; HTTP redirect and explicit CRL exception.
Branch <-> HQ	Explicit routes via the two gateways. Baseline firewall permits only client-br/web-hq TCP 80 and ICMP plus established replies.	Explicit selectors 10.3.2.0/24 <-> 10.3.1.0/24, encrypted policies required.
client-br -> KDC / service	Not enabled in M1.	TCP 8800 on kdc; TCP 8801 on web-hq; AEAD-protected AS/TGS/AP inside tunnel.
Gateway <-> gateway	No IKE daemon or VPN configuration started.	UDP 500/4500 and ESP (IP protocol 50); certificate-authenticated IKEv2.
attacker -> Branch	Route via gw-branch; baseline forwards attacker-source traffic to Branch for later authorized tests.	Testing foothold remains lab-only; final policy tested separately.
attacker -> HQ	No route on attacker; gw-hq drops non-baseline WAN flows, including routed attacker-source HQ attempts.	HQ unreachable; future T10 scan proves boundary.
CA -> services	No private CA material mounted. No signing now.	Offline Root -> Issuing certificate/CRL only; controlled public artifact transfer.

web-hq and kdc have 10.3.2.0/24 via 10.3.1.1. client-br has 10.3.1.0/24 via 10.3.2.1 and WAN via gw-branch. gw-hq routes Branch via 172.16.3.20; gw-branch routes HQ via 172.16.3.10. attacker routes only Branch via 172.16.3.20. No NAT is used. Source-address spoofing by a privileged attacker is a baseline risk, not a claimed authentication control.

Target trust decisions

VPN authenticates only pinned gateways, not every certificate signed by the CA. TLS authenticates the portal end-to-end beyond VPN termination; mTLS binds a request to a staff private-key holder, not necessarily a physical person. KDC is separately trusted for ticket/session-key issuance. Root signs only Issuing CA and its CRL; Issuing cannot create subordinate CAs (pathlen 0). CRL signature verification protects authenticity over HTTP but cannot ensure availability or freshness without nextUpdate checks.

After M3 only IKE and ESP should carry campus application traffic on WAN. ARP is normal link-layer housekeeping and is excluded from the application-confidentiality claim. LAN segments remain outside the ESP tunnel: HTTPS and protocol AEAD still matter. Final fail-closed firewall is future work; M1 deliberately permits scoped plaintext so it can be observed.

Evidence plan

Capture on gw-hq WAN IP 172.16.3.10 using lab/roles/wan-iface.sh. Expected route: client-br -> gw-branch -> WAN -> gw-hq -> web-hq, and return. Preserve original client/server IPs in WAN HTTP capture. Confirm six containers, interfaces/routes, known HTTP body and no XFRM policy before capture. Runtime validation and packet frame numbers remain pending; see lab/README.md.